Network Security Best Practices

3.3.1

Confidentiality, Integrity, and Availability

It is true that the list of network attack types is long. But there are many best practices that you can use to defend your network, as you will learn in this topic.

Network security consists of protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction.

Most organizations follow the CIA information security triad:

- **Confidentiality** – Only authorized individuals, entities, or processes can access sensitive information. It may require using cryptographic encryption algorithms such as AES to encrypt and decrypt data.
- **Integrity** – Refers to protecting data from unauthorized alteration. It requires the use of cryptographic hashing algorithms such as SHA.
- **Availability** – Authorized users must have uninterrupted access to important resources and data. It requires implementing redundant services, gateways, and links.

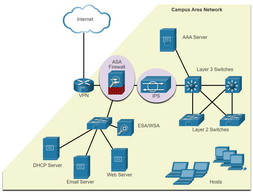
CIA Triad

3.3.2

The Defense-in-Depth Approach

To ensure secure communications across both public and private networks, you must secure devices including routers, switches, servers, and hosts. Most organizations employ a defense-in-depth approach to security. This is also known as a layered approach. It requires a combination of networking devices and services working together. Consider the network in the figure.

Protecting Against Network Attacks



Several security devices and services are implemented to protect an organization's users and assets against TCP/IP threats.

- **VPN** – A router is used to provide secure VPN services with corporate sites and remote access support for remote users using secure encrypted tunnels.
- **ASA Firewall** – This dedicated device provides stateful firewall services. It ensures that internal traffic can go out and come back, but external traffic cannot initiate connections to inside hosts.
- **IPS** – An intrusion prevention system (IPS) monitors incoming and outgoing traffic looking for malware, network attack signatures, and more. If it recognizes a threat, it can immediately stop it.
- **ESA/WSA** – The email security appliance (ESA) filters spam and suspicious emails. The web security appliance filters known and suspicious Internet malware sites.
- **AAA Server** – This server contains a secure database of who is authorized to access and manage network devices. Network devices authenticate administrative users using this database.

All network devices including the router and switches are hardened, which means that they have been secured to prevent threat actors from gaining access and tampering with the devices.

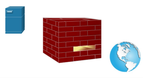
Next, you must secure the data as it travels across various links. This may include internal traffic, but it is more important to protect the data that travels outside of the organization to branch sites, telecommuter sites, and partner sites.

3.3.3

Firewalls

A firewall is a system, or group of systems, that enforces an access control policy between networks. Click Play in the figure to view an animation of how a firewall operates.

Firewall Operation



All firewalls share some common properties:

- Firewalls are resistant to network attacks.
- Firewalls are the only transit points between internal corporate networks and external networks because all traffic flows through the firewall.
- Firewalls enforce the access control policy.

There are several benefits of using a firewall in a network:

- They prevent the exposure of sensitive hosts, resources, and applications to untrusted users.
- They sanitize protocol flow, which prevents the exploitation of protocol flaws.
- They block malicious data from servers and clients.
- They reduce security management complexity by off-loading most of the network access control to a few firewalls in the network.

Firewalls also present some limitations:

- A misconfigured firewall can have serious consequences for the network, such as becoming a single point of failure.
- The firewall software application upgrade and configuration must be handled carefully.
- Users might proactively search for ways around the firewall to receive blocked material, which exposes the network to potential attack.
- Network performance can slow down.
- Unauthorized traffic can be tunneled or hidden so that it appears as legitimate traffic through the firewall.

3.3.4

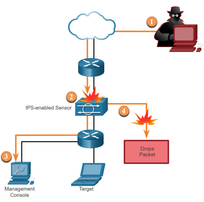
IPS

To defend against fast-moving and evolving attacks, you may need cost-effective detection and prevention systems, such as intrusion detection systems (IDS), or the more scalable intrusion prevention systems (IPS). The network architecture integrates these solutions into the entry and exit points of the network.

IDS and IPS technologies share several characteristics, as shown in the figure. IDS and IPS technologies are both deployed as sensors. An IDS or IPS sensor can be in the form of several different devices:

- A router configured with Cisco IOS IPS software
- A device specifically designed to provide dedicated IDS or IPS services
- A network module installed in an adaptive security appliance (ASA), switch, or router

IPS Operation



The figure shows how an IPS handles denied traffic.

1. The threat actor sends a packet destined for the target laptop.
2. The IPS intercepts the traffic and evaluates it against known threats and the configured policies.
3. The IPS sends a log message to the management console.
4. The IPS drops the packet.

IDS and IPS technologies detect patterns in network traffic using signatures. A signature is a set of rules that an IDS or IPS uses to detect malicious activity. Signatures can be used to detect severe breaches of security, to detect common network attacks, and to gather information. IDS and IPS technologies can detect atomic signature patterns (single-packet) or composite signature patterns (multi-packet).

3.3.5

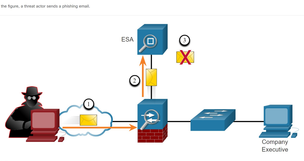
Content Security Appliances

Content security appliances include fine-grained control over email and web browsing for an organization's users.

Cisco Email Security Appliance (ESA)

The Cisco Email Security Appliance (ESA) is a special device designed to monitor Simple Mail Transfer Protocol (SMTP). The Cisco ESA is constantly updated by real-time feeds from the Cisco Talos, which detects and correlates threats and solutions by using a worldwide database monitoring system. This threat intelligence data is pulled by the Cisco ESA every three to five minutes.

In the figure, a threat actor sends a phishing email.



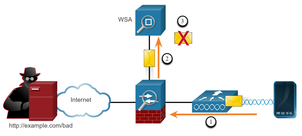
1. Threat actor sends a phishing attack to an important host on the network.
2. The firewall forwards all email to the ESA.
3. The ESA analyzes the email, logs it, and discards it.

Cisco Web Security Appliance (WSA)

The Cisco Web Security Appliance (WSA) is a mitigation technology for web-based threats. It helps organizations address the challenges of securing and controlling web traffic. The Cisco WSA combines advanced malware protection, application visibility and control, acceptable use policy controls, and reporting.

Cisco WSA provides complete control over how users access the Internet. Certain features and applications, such as chat, messaging, video and audio, can be allowed, restricted with time and bandwidth limits, or blocked, according to the organization's requirements. The WSA can perform blacklisting of URLs, URL filtering, malware scanning, URL categorization, web application filtering, and encryption and decryption of web traffic.

In the figure, a corporate user attempts to connect to a known blacklisted site.



1. A user attempts to connect to a website.
2. The firewall forwards the website request to the WSA.
3. The WSA evaluates the URL and determines that it is a known blacklisted site. The WSA discards the packet and sends an access denied message to the user.

3.3.6

Check Your Understanding – Network Security Best Practices

Check your understanding of network security best practices by choosing the BEST answer to the following questions.

1. Which network security device ensures that internal traffic can go out and come back, but external traffic cannot initiate connections to inside hosts?
   - VPN
   - ASA Firewall
   - IPS
   - ESA/WSA
   - AAA Server

2. Which network security device contains a secure database of who is authorized to access and manage network devices?
   - VPN
   - ASA Firewall
   - IPS
   - ESA/WSA
   - AAA Server

3. Which network security device filters known and suspicious Internet malware sites?
   - VPN
   - ASA Firewall
   - IPS
   - ESA/WSA
   - AAA Server

4. Which network security device is used to provide secure services with corporate sites and remote access support for remote users using secure encrypted tunnels?
   - VPN
   - ASA Firewall
   - IPS
   - ESA/WSA
   - AAA Server

5. Which network security device monitors incoming and outgoing traffic looking for malware, network attack signatures, and if it recognizes a threat, it can immediately stop it?
   - VPN
   - ASA Firewall
   - IPS
   - ESA/WSA
   - AAA Server

Check

Show Me

Reset